CONTROLE DE CONTAS PRIVILEGIADAS

Active Directory — Fatec Barueri | Projeto AD 2026

1. Objetivo

Estabelecer diretrizes institucionais para criação, utilização, controle, monitoramento e revisão de contas privilegiadas no Active Directory da Fatec Barueri. O objetivo é garantir que privilégios administrativos sejam concedidos somente a pessoas autorizadas, utilizados para finalidades legítimas e mantidos sob controle da equipe de TI.

A política está alinhada à estrutura de segurança do projeto, que adota o princípio do menor privilégio, controle de identidades, auditoria e administração centralizada do ambiente.

2. Escopo

Aplica-se às contas com capacidade de realizar alterações administrativas no domínio adm.fatecbarueri.local, nos servidores, estações, OUs, grupos, GPOs, recursos compartilhados e demais componentes da infraestrutura.

• Administradores de domínio: contas com privilégios elevados sobre o Active Directory.

• Administradores de servidores: contas destinadas à administração de servidores e serviços.

• Administradores de estações: contas destinadas a atividades administrativas em computadores.

• Contas de serviço: identidades utilizadas por aplicações e serviços, quando necessárias.

• Equipe de TI: responsável pelo gerenciamento e controle das contas privilegiadas.

3. Princípios de Controle

• Necessidade: o privilégio deve existir somente quando houver necessidade operacional.

• Menor privilégio: cada conta deve receber somente as permissões necessárias.

• Uso individual: atividades administrativas devem ser atribuídas a uma identidade identificável.

• Segregação: contas administrativas devem ser separadas das contas utilizadas para atividades comuns.

• Rastreabilidade: operações administrativas devem poder ser associadas ao responsável.

• Revisão periódica: privilégios devem ser revisados para identificar acessos desnecessários.

• Revogação: privilégios devem ser removidos quando a necessidade deixar de existir.

4. Estrutura das Contas Privilegiadas

As contas privilegiadas devem ser organizadas de acordo com a função administrativa exercida. O projeto concentra a administração técnica do domínio na equipe de TI, responsável por usuários, grupos, OUs, GPOs, servidores, compartilhamentos, backups e logs.

A documentação do projeto define que a TI possui controle administrativo sobre esses componentes do ambiente. □filecite□turn1file0□L745-L750□

5. Tipos de Contas

5.1 Conta Administrativa Individual

Conta utilizada por um profissional autorizado para executar atividades administrativas. Deve possuir identificação individual e não deve ser compartilhada entre integrantes da equipe.

5.2 Conta de Uso Comum

Conta utilizada para atividades rotineiras, como acesso a e-mail, sistemas acadêmicos, navegação e recursos comuns. Não deve possuir privilégios administrativos desnecessários.

5.3 Conta de Serviço

Conta utilizada por serviços ou aplicações. Deve possuir somente as permissões necessárias para a execução do serviço e não deve ser utilizada para login interativo por pessoas, salvo necessidade técnica formalmente justificada.

5.4 Conta de Emergência

Conta destinada a situações excepcionais de recuperação ou continuidade operacional. Seu uso deve ser restrito, registrado e revisado após cada utilização.

6. Matriz de Controle

Atividade / Recurso	Usuário comum	TI	Controle exigido
Acessar AD	Negado	Conforme função	Autorização + auditoria
Criar usuários	Negado	Permitido	Registro da operação
Alterar usuários	Negado	Permitido	Rastreabilidade
Criar/alterar grupos	Negado	Permitido	Validação da necessidade
Alterar OUs	Negado	Permitido	Controle de mudança
Alterar GPOs	Negado	Permitido	Registro e revisão
Administrar servidores	Negado	Conforme função	Auditoria
Consultar logs	Negado	Permitido	Proteção dos registros

7. Regras para Criação e Concessão

• Toda conta privilegiada deve possuir responsável identificado.

• A criação deve ser solicitada e autorizada conforme o procedimento institucional.

• O privilégio deve corresponder à função efetivamente exercida.

• A conta deve ser vinculada aos grupos administrativos estritamente necessários.

• Não devem ser concedidos privilégios superiores aos necessários para a tarefa.

• A criação, alteração ou remoção deve ser registrada para fins de auditoria.

8. Separação entre Conta Comum e Conta Administrativa

Sempre que tecnicamente viável, o profissional de TI deve utilizar uma conta comum para atividades cotidianas e uma conta administrativa separada para tarefas que exigem privilégios elevados. Essa separação reduz a exposição de credenciais administrativas e facilita a identificação de operações privilegiadas.

• Conta comum: atividades cotidianas.

• Conta administrativa: administração de AD, servidores, GPOs e demais recursos autorizados.

• Credenciais administrativas não devem ser utilizadas desnecessariamente em atividades comuns.

9. Autenticação e Proteção das Credenciais

• Credenciais administrativas são individuais e não devem ser compartilhadas.

• Senhas devem obedecer à política institucional de segurança.

• Não armazenar senhas administrativas em arquivos, planilhas ou locais sem proteção adequada.

• Evitar autenticação administrativa em equipamentos não confiáveis.

• Contas administrativas devem estar sujeitas às políticas de bloqueio e auditoria do domínio.

10. Administração de Grupos Privilegiados

A associação a grupos administrativos deve ser tratada como uma concessão de privilégio. A TI deve manter controle sobre os membros desses grupos e revisar periodicamente sua composição.

• Manter grupos administrativos com finalidade específica.

• Evitar inclusão de usuários diretamente em grupos de alto privilégio sem justificativa.

• Revisar membros dos grupos administrativos periodicamente.

• Remover imediatamente membros que não necessitem mais do privilégio.

11. Auditoria e Monitoramento

• Registrar autenticações e falhas de autenticação.

• Registrar alterações em usuários, grupos, OUs e GPOs.

• Monitorar atividades administrativas relevantes.

• Manter logs protegidos contra alteração não autorizada.

• Realizar análise periódica dos registros.

O projeto prevê auditoria de logins e falhas de autenticação, além de relatórios periódicos para análise da equipe de TI. filecite turn1file0 L459-L474

12. Revisão e Recertificação de Privilégios

• Revisar periodicamente as contas privilegiadas existentes.

• Confirmar se cada conta ainda possui necessidade operacional.

• Confirmar se os privilégios correspondem à função atual.

• Remover contas sem uso ou sem justificativa.

• Registrar o resultado da revisão como evidência.

13. Desligamento, Mudança de Função e Inatividade

Alterações no vínculo institucional ou na função do usuário devem provocar revisão imediata dos privilégios. O projeto prevê controle do ciclo de vida das contas, incluindo criação, alteração, bloqueio, inativação e exclusão. filecite turn1file0 L45-L48

• Desligamento: bloquear/remover os acessos conforme procedimento.

• Mudança de função: revisar grupos e privilégios.

• Inatividade: aplicar as regras institucionais para contas inativas.

• Privilégios temporários: remover ao final do período autorizado.

14. Contas de Serviço

• Devem possuir finalidade documentada.

• Devem receber somente as permissões necessárias.

• Não devem possuir privilégios administrativos amplos sem justificativa técnica.

• Seu uso deve ser monitorado e revisado.

• Credenciais devem ser protegidas e mantidas sob controle da TI.

15. Contas de Emergência

• Utilização somente em situações excepcionais.

• Acesso restrito à equipe autorizada.

• Uso obrigatoriamente registrado.

• Credenciais protegidas e controladas.

• Revisão das ações realizadas após a utilização.

16. Exemplos Práticos

Exemplo 1 — Criação de usuário: um técnico precisa criar uma conta de aluno. A operação é realizada com uma conta administrativa autorizada, utilizando a OU e os grupos correspondentes ao perfil do aluno.

Exemplo 2 — Alteração de GPO: uma nova restrição precisa ser aplicada aos laboratórios. Somente a equipe de TI autorizada altera a GPO, registra a mudança e valida o resultado.

Exemplo 3 — Mudança de função: um funcionário deixa um setor administrativo e passa para outro. Os grupos e permissões anteriores são revisados antes da concessão dos novos acessos.

Exemplo 4 — Conta de emergência: diante de uma falha crítica que impeça a administração normal do domínio, a conta de emergência pode ser utilizada por responsável autorizado, com registro posterior das ações realizadas.

17. Responsabilidades

TI: criar, administrar, monitorar e revisar contas privilegiadas; controlar grupos administrativos; manter registros e aplicar medidas de segurança.

Responsáveis pela infraestrutura: utilizar privilégios somente para as atividades autorizadas e comunicar alterações necessárias.

Demais usuários: não tentar obter, utilizar ou compartilhar credenciais administrativas.

18. Justificativa Técnica

O controle de contas privilegiadas reduz o risco associado ao uso indevido de credenciais com alto nível de acesso. A separação entre contas comuns e administrativas, a concessão baseada em necessidade, a auditoria e a revisão periódica tornam as operações administrativas mais rastreáveis e compatíveis com o princípio do menor privilégio adotado no projeto.

A estrutura de segurança do projeto também prevê gestão de identidades, auditoria, políticas de GPO e controle de acesso como requisitos do ambiente. filecite turn1file0 L608-L640

19. Controle e Revisão do Documento

• O documento deve ser revisado quando houver alteração significativa no ambiente do AD.

• Alterações na estrutura de grupos, OUs, GPOs ou perfis devem ser avaliadas quanto ao impacto sobre as contas privilegiadas.

• A versão final deve ser revisada pela equipe e validada pelo P.O.

• A versão validada deve ser incorporada à documentação oficial do projeto.

20. Critério de Validação

• Artefato concluído e revisado pela equipe.

• Documento validado pelo P.O.

• Documento anexado ao card do Trello.

• Conteúdo refletido na documentação oficial e na monografia.

• Registro da validação mantido como evidência do projeto.

Documento: Controle de Contas Privilegiadas — Active Directory

Projeto: AD Fatec Barueri — 2026

Domínio: adm.fatecbarueri.local

Status: Documento para revisão e validação do P.O.